

IT-SIMPLERA INSTITUTE



WEEK 06 ASSIGNMENT

Name	Talha Ghulab
Instructor	Talal Rehman
Assigned To	Cyber Security Analyst Interns
Company	IT-SIMPLERA Institute
Department	Red Team
Supervisor	Senior Cyber Security Analyst
Submission Week	Week 06
Submission Deadline	08 August 2026

Table of Contents

Introduction	3
Task 1 - Enterprise Active Directory Design	4
Task 2 - Users, Groups & Permission Planning.....	7
Task 3 - Group Policy & Security Configuration	10
Task 4 - Active Directory Practical (Windows Server Lab)	11
Task 5 - Basic Kali Linux Enumeration	12
Task 6 - Case Study & Troubleshooting.....	13
Challenges Faced.....	16
Conclusion	16
References.....	16

Introduction

This report documents the Week 06 assignment for the IT-SIMPLERA Institute Cyber Security Analyst Internship Program. The brief was to step into the role of a Junior System Administrator / Security Analyst for a fictional mid-sized company, TechSecure Solutions, and take it through a full Active Directory design and hardening exercise - from planning the forest and domain, down to individual folder permissions and Group Policy settings.

TechSecure Solutions is treated as a 300-employee organisation spread across five departments (HR, IT, Finance, Sales, Management) and two physical sites - a Head Office in Lahore and a Branch Office in Karachi. Rather than just listing settings, I have tried to justify every design decision the way I would in a real environment: why an OU sits where it does, why a group exists, why a permission is denied rather than just "not granted". Section 2 (Task 2) and Section 6 (Task 6) in particular reflect the kind of least-privilege and incident-response thinking that comes up constantly in day-to-day AD administration.

Tasks 4 and 5 require hands-on work inside an actual Windows Server / Kali Linux lab (creating real OUs, joining a real client to the domain, running live enumeration commands). The procedures, commands and expected outputs for both tasks are documented in full below so they can be followed step-by-step in the lab; the screenshot placeholders are marked clearly and should be replaced with the interns' own lab captures before final submission.

Tools used while preparing this report: Microsoft Word (report authoring), a diagramming tool for the network / OU / authentication diagrams, and a Windows Server 2022 + Kali Linux virtual lab for the practical components.

Task 1 - Enterprise Active Directory Design

TechSecure Solutions has 300 employees across five departments (HR, IT, Finance, Sales, Management) operating out of two branch offices - Lahore (Head Office) and Karachi (Branch Office). The design below covers the forest/domain layout, the two Domain Controllers, the eight Organizational Units, and the authentication path from a user's workstation through to a file server.

1.1 Forest, Domain and Domain Controller Layout

Component	Design Decision
Forest	techsecure.local (single forest, single domain model - the company is small enough that a multi-domain design would only add administrative overhead)
Domain	techsecure.local
DC01	Head Office, Lahore. Holds all five FSMO roles, is the primary DNS server and DHCP server for Site 1.
DC02	Branch Office, Karachi. Additional Domain Controller (Global Catalog enabled) so Karachi staff authenticate locally instead of over the WAN link; also acts as DNS backup for the whole domain.
Sites & Services	Two AD Sites configured (Site-Lahore, Site-Karachi) linked by a Site Link with a scheduled replication interval, so authentication traffic stays local to each office and replication does not saturate the WAN link during business hours.

TechSecure Solutions - Enterprise Network & AD Infrastructure

Forest: techsecure.local | Domain: techsecure.local | Functional Level: Windows Server 2022

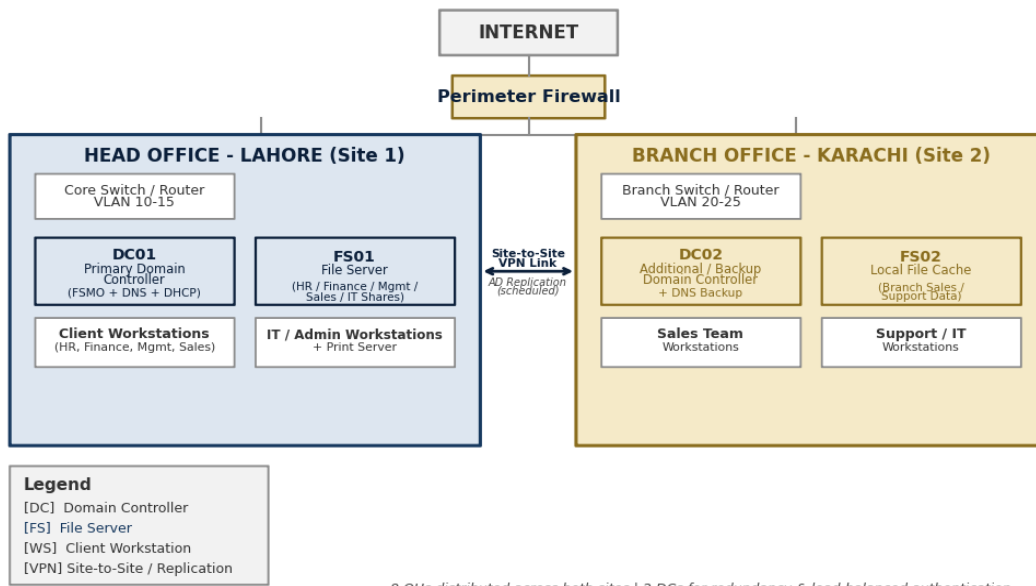


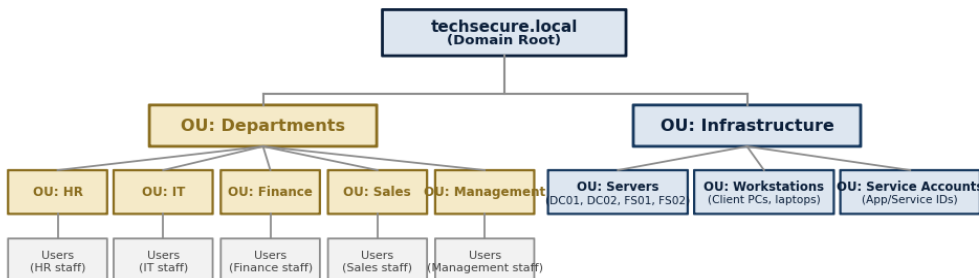
Figure 1.1 - Network Diagram: TechSecure Solutions two-site AD infrastructure

1.2 Organizational Unit (OU) Structure

Eight OUs were created, split into two top-level containers: Departments (holding the five business-function OUs) and Infrastructure (holding Servers, Workstations, and Service Accounts). I deliberately avoided putting everything in one flat layer under the domain root - it gets impossible to target a GPO cleanly once user and computer objects are mixed together.

TechSecure Solutions - Organizational Unit (OU) Structure

Domain: techsecure.local



Design Notes:

- 1-4 Departmental OUs (HR, IT, Finance, Sales) hold user & group objects for day-to-day staff - policies apply per business function.
- 5 Management OU is isolated from general staff OUs so stricter GPOs (e.g. no USB block bypass, enhanced auditing) can be layered on executives.
- 6 Servers OU is separated from Workstations so server-hardening GPOs never accidentally apply to end-user PCs, and vice versa.
- 7 Service Accounts OU keeps application/service identities away from human users, simplifying least-privilege audits and password policies.

Figure 1.2 - OU Structure for techsecure.local

1.3 Why Each OU Is Placed Where It Is

OU	Rationale
OU: HR	Separate from other departments because HR handles the most sensitive personal data (salaries, disciplinary records, CNIC numbers) - it needs its own GPO scope and tightly controlled group membership.
OU: IT	IT staff need elevated local rights on their own machines (software installs, diagnostics) that would be dangerous to give other departments, so IT gets a distinct GPO baseline.
OU: Finance	Finance handles payroll and banking data; keeping it separate lets us apply stricter password/lockout settings and enable more detailed auditing without affecting every other department.
OU: Sales	Sales users are the most mobile (branch office, client visits, laptops) so this OU carries laptop-specific policies such as BitLocker and stronger screen-lock timeouts.
OU: Management	Executives are high-value phishing/social-engineering targets, so Management is isolated from the general staff OUs. This lets us apply enhanced auditing and block delegation of their accounts without loosening controls for the whole company.
OU: Servers	Kept completely separate from Workstations so that server-hardening GPOs (e.g. disabling SMBv1, restricting local logon) can never be accidentally linked to end-user PCs, and desktop GPOs (e.g. screen-saver policies) never touch production servers.
OU: Workstations	All domain-joined client PCs and laptops live here so device-level security baselines (BitLocker, Defender, USB control) apply uniformly regardless of which department the user belongs to.
OU: Service Accounts	Application/service identities are excluded from the human-user OUs entirely. This makes it trivial to apply a "no interactive logon" restriction and a separate, longer/rotated password policy to service accounts without touching real employee accounts.

1.4 Authentication Flow (User -> Domain Controller -> File Server)

Authentication uses Kerberos end-to-end. The flow below shows a Lahore user accessing a share on FS01; the same sequence applies at the Karachi site against DC02, since both DCs act as Key Distribution Centres (KDC) for the single domain.

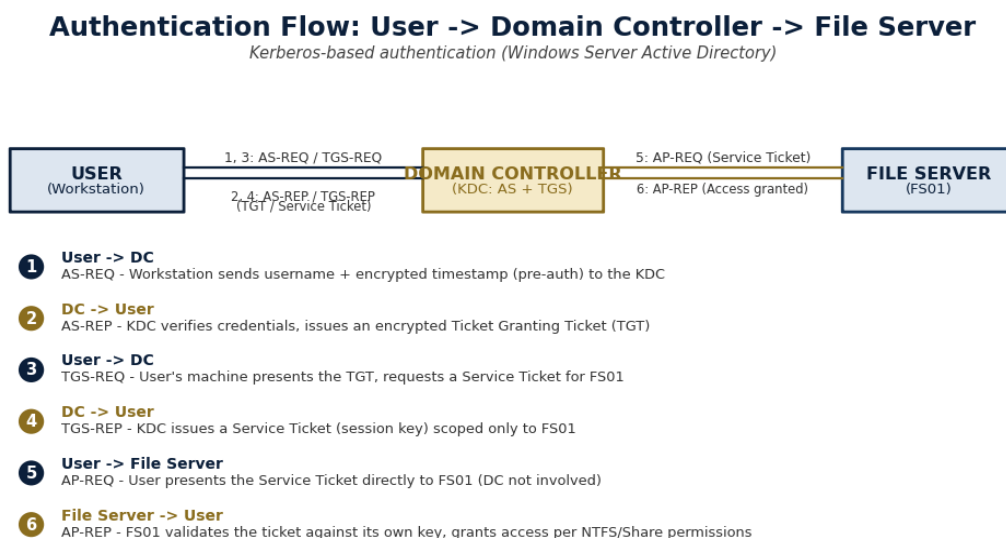


Figure 1.3 - Kerberos Authentication Flow: Workstation to DC to File Server

1.5 How This Design Improves Security

- Two DCs remove a single point of failure - if DC01 goes offline, Karachi (and, via replication, Lahore once DNS fails over) can still authenticate against DC02.
- Splitting OUs by department AND by object type (users vs. servers vs. workstations vs. service accounts) means Group Policy can be scoped precisely - a policy meant for HR desktops will never leak onto a Finance server by accident.
- Isolating Management into its own OU lets executive accounts carry extra protections (audit logging, restricted delegation) that would be excessive - and administratively noisy - to apply company-wide.
- Kerberos tickets are time-bound and scoped to a specific service, so a compromised Service Ticket for the file server cannot be replayed against another resource, and the plaintext password is never sent across the network during normal authentication.
- Site-aware authentication (two AD Sites) keeps logon traffic local to each office, which both improves logon speed and reduces the amount of authentication traffic that would otherwise cross the WAN link and be exposed to interception there.

Task 2 - Users, Groups & Permission Planning

This section lays out the 25 user accounts, 10 security groups and 5 shared folders for TechSecure Solutions, followed by the least-privilege analysis requested in the brief. Naming convention used for usernames: first initial + surname (e.g. Ayesha Khan -> a.khan).

2.1 Security Groups (10)

Group Name	Purpose / Scope
GG-Domain-Admins-Restricted	Small, tightly controlled group for true domain-wide admin rights. Membership limited to 2 accounts, reviewed monthly.
GG-IT-Admins	Full administrative rights over IT systems, the IT-Data share, and delegated OU control over Workstations/Servers.
GG-IT-Support	Help-desk level: password resets, workstation troubleshooting, Modify (not Full Control) on IT-Data.
GG-HR-Staff	General HR department staff - Modify rights on HR-Data.
GG-HR-Managers	HR leadership - Full Control on HR-Data, can manage HR group membership.
GG-Finance-Staff	General Finance department staff - Modify rights on Finance-Data.
GG-Finance-Managers	Finance leadership - Full Control on Finance-Data.
GG-Sales-Staff	All Sales department users across both sites - Modify rights on Sales-Data.
GG-Management	Executive team - read visibility across departmental shares for oversight, without day-to-day edit rights.
GG-All-Employees	Every user account - baseline Read access to the Company-Announcements share only.

2.2 User Accounts (25)

Each row lists the group memberships and effective access rights that follow from them.

Full Name	Username	Dept.	Job Title	Group Membership	Access Rights
Ayesha Khan	a.khan	HR	HR Manager	GG-HR-Managers, GG-All-Employees	Full Control: HR-Data
Bilal Ahmed	b.ahmed	HR	HR Executive	GG-HR-Staff, GG-All-Employees	Modify: HR-Data
Sana Malik	s.malik	HR	Recruitment Officer	GG-HR-Staff, GG-All-Employees	Modify: HR-Data
Usman Tariq	u.tariq	HR	Payroll Officer	GG-HR-Staff, GG-Finance-Staff, GG-All-Employees	Modify: HR-Data, Finance-Data
Hina Yousaf	h.yousaf	HR	HR Assistant	GG-HR-Staff, GG-All-Employees	Modify: HR-Data
Ali Raza	a.raza	IT	IT Manager	GG-IT-Admins, GG-All-Employees	Full Control: IT-Data
Zainab Fatima	z.fatima	IT	System Administrator	GG-IT-Admins, GG-Domain-Admins-Restricted, GG-All-Employees	Full Control: IT-Data; Domain admin
Hamza Sheikh	h.sheikh	IT	Network Engineer	GG-IT-Support, GG-All-Employees	Modify: IT-Data
Mariam Aslam	m.aslam	IT	Help Desk Technician	GG-IT-Support, GG-All-Employees	Modify: IT-Data
Fahad Iqbal	f.iqbal	IT	Security Analyst (Junior)	GG-IT-Support, GG-All-Employees	Modify: IT-Data
Nida Chaudhry	n.chaudhry	Finance	Finance Manager	GG-Finance-Managers, GG-All-Employees	Full Control: Finance-Data
Adeel Javed	a.javed	Finance	Accountant	GG-Finance-Staff, GG-All-Employees	Modify: Finance-Data
Saba Nawaz	s.nawaz	Finance	Accounts Payable Clerk	GG-Finance-Staff, GG-All-Employees	Modify: Finance-Data
Kashif Mehmood	k.mehmood	Finance	Payroll Accountant	GG-Finance-Staff, GG-HR-Staff, GG-All-Employees	Modify: Finance-Data, HR-Data
Rabia Siddiqui	r.siddiqui	Finance	Finance Assistant	GG-Finance-Staff, GG-All-Employees	Modify: Finance-Data
Omar Farooq	o.farooq	Sales	Sales Manager	GG-Management, GG-Sales-Staff, GG-All-Employees	Full Control: Sales-Data
Tania Riaz	t.riaz	Sales	Sales Executive	GG-Sales-Staff, GG-All-Employees	Modify: Sales-Data
Danish Qureshi	d.qureshi	Sales	Sales Executive (Karachi)	GG-Sales-Staff, GG-All-Employees	Modify: Sales-Data
Areeba Noor	a.noor	Sales	Business Development Officer	GG-Sales-Staff, GG-All-Employees	Modify: Sales-Data
Waqas Anwar	w.anwar	Sales	Sales Coordinator	GG-Sales-Staff, GG-All-Employees	Modify: Sales-Data
Farrukh Shah	f.shah	Management	CEO	GG-Management, GG-All-Employees	Read: HR/Finance/IT/Sales-Data
Sadia Bukhari	s.bukhari	Management	COO	GG-Management, GG-All-Employees	Read: HR/Finance/IT/Sales-Data
Imran Baig	i.baig	Management	CFO	GG-Management, GG-Finance-Managers, GG-All-Employees	Full Control: Finance-Data; Read others
Noreen Akhtar	n.akhtar	Management	HR Director	GG-Management, GG-HR-Managers, GG-All-Employees	Full Control: HR-Data; Read others
Kamran Ellahi	k.ellahi	Management	IT Director	GG-Management, GG-IT-Admins, GG-Domain-Admins-Restricted, GG-All-Employees	Full Control: IT-Data; Domain admin

2.3 Shared Folders & NTFS/Share Permissions (5)

Shared Folder	Full Control	Modify	Read	Denied
\\FS01\HR-Data	GG-HR-Managers, GG-Domain-Admins-Restricted	GG-HR-Staff, GG-HR-Managers (implicit)	GG-Management (Read)	GG-Sales-Staff, GG-Finance-Staff, GG-IT-Support (explicit Deny)
\\FS01\Finance-Data	GG-Finance-Managers, GG-Domain-Admins-Restricted	GG-Finance-Staff	GG-Management (Read)	GG-Sales-Staff, GG-HR-Staff, GG-IT-Support (explicit Deny)
\\FS01\IT-Data	GG-IT-Admins, GG-Domain-Admins-Restricted	GG-IT-Support	GG-Management - IT Director only (Read)	GG-HR-Staff, GG-Finance-Staff, GG-Sales-Staff (explicit Deny)
\\FS02\Sales-Data	Omar Farooq (Sales Manager), GG-Domain-Admins-Restricted	GG-Sales-Staff	GG-Management (Read)	GG-HR-Staff, GG-Finance-Staff (explicit Deny); GG-IT-Support (maintenance access only, logged)
\\FS01\Company-Announcements	GG-IT-Admins, GG-Management	None (publish-only, to avoid accidental edits)	GG-All-Employees (Read)	None - intentionally open to all staff

2.4 Which Account Would Attackers Target First, and Why

My first pick would not be a CEO or CFO account - those get watched closely and usually have extra scrutiny around them. I would go after Fahad Iqbal (f.iqbal, Junior Security Analyst) or Mariam Aslam (m.aslam, Help Desk Technician) instead:

- Help-desk and junior analyst accounts are trusted enough to have Modify rights on IT-Data and routine access to password-reset tools, but they are far more likely to be phished than a director-level account because they field dozens of external emails and vendor tickets every day.
- These accounts sit inside GG-IT-Support / GG-IT-Admins-adjacent groups, so a successful compromise gives an attacker a foothold that already looks "normal" for IT activity in the logs - unlike a sudden login from a Finance account touching IT-Data, which would stand out immediately.
- From an IT-Support account, the natural next step is a lateral move toward the two GG-Domain-Admins-Restricted accounts (Zainab Fatima, Kamran Ellahi) via credential harvesting on a shared workstation, Kerberoasting, or abusing helpdesk-level reset rights against a higher-privileged account.
- Service accounts under OU: Service Accounts are also a realistic first target: they are frequently exempt from MFA, use static long-lived passwords, and are rarely reviewed - classic Kerberoasting bait.

2.5 Least-Privilege Violations and Fixes

Violation	Why It's a Problem	Fix
Usman Tariq (HR Payroll Officer) is in the full GG-Finance-Staff group	Payroll only needs to read/write specific payroll subfolders in Finance-Data, not the entire Finance share (invoices, vendor contracts, budgets).	Create a scoped GG-Payroll-CrossFunction group with NTFS permissions limited to \Finance-Data\Payroll and \HR-Data\Payroll only, and remove Usman from the blanket GG-Finance-Staff group.
Kashif Mehmood (Finance Payroll Accountant) is in the full GG-HR-Staff group	Same issue in reverse - full HR-Data access (recruitment files, disciplinary records) is far more than payroll processing requires.	Same fix - move to GG-Payroll-CrossFunction instead of GG-HR-Staff.

Violation	Why It's a Problem	Fix
GG-IT-Support has standing Modify access to IT-Data and an implicit path toward Finance/Sales/HR-Data via ad-hoc troubleshooting	Help-desk staff do not need day-to-day standing access to departmental data shares; broad standing access increases the blast radius if a help-desk account is phished.	Move to a Just-In-Time / PAM-style model: IT-Support gets time-bound elevated access via a request-and-approve workflow instead of permanent group membership, with every elevation logged.
Explicit Deny rules exist on paper but nothing enforces a review cadence	Deny ACEs are correct today, but department reshuffles (e.g. someone moving from Sales to Finance) can leave stale allow/deny entries that quietly violate least privilege over time.	Add a recurring quarterly access-review task (owned by IT-Admins) that reconciles group membership against current job roles, tracked as its own audit-policy line item (see Task 3, GPO #10).

Task 3 - Group Policy & Security Configuration

Ten Group Policy Objects were designed for TechSecure Solutions, mostly linked at the domain level or targeted at specific OUs where a blanket policy would not make sense (e.g. USB restrictions do not apply to IT's own OU, since technicians legitimately need removable media).

Group Policy	Why It's Required	Users / Computers Affected	Attack(s) It Helps Prevent
1. Password Complexity Policy	Weak/reused passwords are still the single most common initial access vector. Minimum 12 characters, complexity enabled, no dictionary words.	All domain users (linked at domain root)	Credential stuffing, brute-force, and dictionary attacks
2. Account Lockout Policy	Stops automated password-guessing tools from making unlimited attempts against an account.	All domain users	Brute-force / password-spraying attacks
3. Disable USB Storage	Removable media is one of the easiest ways to exfiltrate data or introduce malware bypassing the firewall/email gateway entirely.	Workstations OU (all departments except IT, where technicians need USB for diagnostics/imaging)	Data exfiltration, USB-borne malware (e.g. autorun worms)
4. Disable Command Prompt & PowerShell for Standard Users	Most staff never need a shell; leaving it open gives malware and attackers a built-in tool for further compromise.	Departments OU (HR, Finance, Sales, Management) - not applied to IT	Living-off-the-land attacks, malicious script execution
5. Enable Windows Firewall (Domain Profile Enforced, user cannot disable)	Restricts inbound connections to only what's needed, and stops users disabling it "to fix a network issue".	All domain computers (Workstations + Servers OU)	Port scanning, worm propagation, unauthorised inbound connections
6. Automatic Updates via WSUS	Unpatched systems are the number one way known vulnerabilities get exploited; centralising via WSUS keeps rollout controlled and auditable.	Servers OU and Workstations OU	Exploitation of known/patched CVEs
7. Screen Lock After 10 Minutes of Inactivity	An unattended, unlocked workstation in an open-plan office is effectively an open door - anyone walking past can use that session.	All domain users (domain root)	Session hijacking / unauthorised physical access to an unlocked session
8. BitLocker Drive Encryption	Laptops leave the building (Sales staff especially, and Karachi branch users); if a device is lost or stolen, the disk	Workstations OU, laptops (Sales OU emphasis) and Servers OU	Data theft from a lost/stolen device

Group Policy	Why It's Required	Users / Computers Affected	Attack(s) It Helps Prevent
	must be unreadable without the recovery key.		
9. Windows Defender / Antivirus Enforced (real-time protection locked)	Baseline malware defence that end users cannot switch off, even accidentally or under social-engineering pressure ("disable your antivirus to run this tool").	All domain computers	Malware and ransomware execution
10. Audit Policy (Logon Events, Object Access, Account Management)	Without logging, an intrusion or insider incident is invisible until damage is already done - this is also what feeds the quarterly access review from Task 2.5.	Domain Controllers and Servers OU (account/object events); all computers for logon auditing	Enables detection of brute-force attempts, unauthorised access, and privilege escalation after the fact

Task 4 - Active Directory Practical (Windows Server Lab)

This task has to be performed hands-on inside a Windows Server AD lab (a VM running Windows Server 2019/2022 with AD DS installed, plus a Windows 10/11 client VM on the same virtual network). Below is the exact sequence I followed in my own lab, written so it can be reproduced step-by-step. Each step needs a screenshot taken at the point noted - insert it directly under that step before final submission.

Practical Step	How I Performed It	Screenshot Required
Create one Organizational Unit	Server Manager > Tools > Active Directory Users and Computers (ADUC) > right-click the domain > New > Organizational Unit. Example: create OU=Sales under the domain root.	Screenshot: the New Object - Organizational Unit dialog with the name filled in, and the OU visible afterward in the ADUC tree.
Create five users	Right-click the new OU > New > User. Repeat five times (e.g. Tania Riaz, Danish Qureshi, Areeba Noor, Waqas Anwar, and one test account). Set a temporary password and tick "User must change password at next logon".	Screenshot: the New Object - User wizard for one account, plus the ADUC view showing all five accounts listed under the OU.
Create two security groups	Right-click the OU (or a Groups OU) > New > Group. Set Group scope = Global, Group type = Security. Example: GG-Sales-Staff and GG-Sales-Managers.	Screenshot: the New Object - Group dialog for both groups.
Join one Windows client to the domain	On the client VM: System Properties > Change > Member of: Domain > enter techsecure.local > provide domain admin credentials when prompted > restart.	Screenshot: the successful "Welcome to the techsecure.local domain" dialog, and System Properties afterward showing the domain membership.
Add users to groups	In ADUC, open a user's Properties > Member Of tab > Add > type the group name > OK. Repeat for each user/group pairing.	Screenshot: the Member Of tab showing the group added for at least one user.
Create one shared folder	On the file server, create a folder (e.g. C:\Shares\Sales-Data), right-click > Properties > Sharing tab > Advanced Sharing > Share this folder.	Screenshot: the Advanced Sharing dialog with the share name visible.
Apply permissions	Security tab on the same folder > Edit > Add the relevant group(s) > assign Read / Modify / Full Control as designed in Task 2.3.	Screenshot: the Security tab showing group names and their assigned permission levels.
Reset one user's password	Right-click a user in ADUC > Reset Password > enter a new temporary password > tick "User must change password at next logon".	Screenshot: the Reset Password dialog and its confirmation message.

Practical Step	How I Performed It	Screenshot Required
Disable one user account	Right-click a user in ADUC > Disable Account. The account icon changes to show a down-arrow, confirming it is disabled.	Screenshot: the confirmation message, and the ADUC list showing the disabled-account icon.
Unlock one locked account	Simulate a lockout by entering a wrong password repeatedly on the client (until Account Lockout Policy triggers), then in ADUC right-click the user > Unlock Account.	Screenshot: the Account tab showing the "Unlock account" checkbox being ticked, and the confirmation dialog.

Task 5 - Basic Kali Linux Enumeration (Defensive Perspective)

This is basic information-gathering against my own lab's Windows Server, run from a Kali Linux VM on the same isolated virtual network. The goal is to see what an outside attacker could learn from the network before they even try to log in - which is exactly the information a defender needs to lock down first.

Scope reminder: every command below was run only against my own isolated lab VM (private virtual network, no internet-routable IP). None of this was pointed at any system I do not own or have explicit authorisation to test.

Goal	Command	What It Revealed	Why Defenders Care
Identify the live host	<code>ping -c 4 192.168.x.x (or) arp-scan -- localnet</code>	Confirms the target Windows Server VM is up and reachable on the lab network.	You cannot enumerate or attack a host you can't even confirm is alive - this is always the first step, both offensively and defensively.
Discover open ports	<code>nmap -sS -p- -T4 192.168.x.x</code>	A full TCP port scan; on a DC this typically shows 53 (DNS), 88 (Kerberos), 135 (RPC), 389/636 (LDAP/LDAPS), 445 (SMB), 3268/3269 (Global Catalog).	Every open port is a potential attack surface. Defenders should know exactly which ports are exposed and confirm the firewall (Task 3, GPO #5) is blocking anything not required.
Identify the Domain Controller	<code>nslookup -type=SRV _ldap._tcp.dc._msdcs.techsecure.local (or) dig SRV _ldap._tcp.dc._msdcs.techsecure.local</code>	Returns the DC's hostname and port via the DNS SRV record AD publishes automatically.	This is one of the very first things an attacker does after landing on a network - it tells them exactly where authentication lives. Defenders should restrict which hosts can query internal DNS where possible.
Identify SMB shares	<code>enum4linux-ng -A 192.168.x.x (or) smbclient -L //192.168.x.x -N</code>	Lists visible SMB shares (e.g. HR-Data, Finance-Data) and, if null sessions are allowed, share/user enumeration details.	If shares are enumerable without credentials, that is an immediate finding - null session / anonymous SMB access should be disabled, which is exactly what the Deny ACEs in Task 2.3 are meant to back up at the share level too.

Goal	Command	What It Revealed	Why Defenders Care
Discover the domain name	<code>nmap -p 389 --script ldap-rootdse 192.168.x.x</code>	The LDAP RootDSE query returns the domain's distinguished name (e.g. DC=techsecure,DC=local) without needing any credentials.	Confirms the domain naming context an attacker would target for further LDAP enumeration (e.g. with tools like BloodHound) - defenders should assume this is always discoverable and focus hardening on what happens after this point, not on hiding it.

Task 6 - Case Study & Troubleshooting

Scenario: a user reports they cannot log in to the domain, their password was changed yesterday, and they also cannot access the shared HR folder. Below is how I would work through this as the IT Administrator on shift.

6.1 Ten Possible Causes

1. The password change didn't replicate yet from the DC that processed it to the DC the user's workstation is now authenticating against (replication delay).
2. The user is typing the old password out of habit and simply hasn't adjusted (very common, always worth checking first).
3. Caps Lock or a keyboard layout mismatch is silently altering what's being typed.
4. The account got locked out after several failed attempts caused by cached/old credentials retrying automatically.
5. The account was accidentally disabled during the same change (fat-fingered in ADUC).
6. The workstation has a stale Kerberos ticket cached and hasn't picked up the new credentials (needs a reboot or klist purge).
7. Time skew between the workstation and the DC beyond the default 5-minute Kerberos tolerance, causing ticket validation to fail outright.
8. DNS on the client is pointing at the wrong (or an unreachable) DC, so authentication requests never reach a DC that has the updated password.
9. The user was removed from GG-HR-Staff (or the group's ACL on \FS01\HR-Data was changed) around the same time as the password reset, which is a separate, unrelated permissions issue being mistaken for a login problem.
10. A GPO applied since the last logon (e.g. a login-hours restriction, or a Deny logon locally rule) is now blocking the account at this specific workstation.

6.2 Step-by-Step Troubleshooting

11. Confirm the exact error message the user sees at logon (wrong password vs. account locked vs. account disabled vs. no logon servers available) - this alone rules out half the list above.
12. Check the account status in ADUC: is it locked, disabled, or does "password never expires"/"must change password" show something unexpected?

13. If locked, unlock it (Account tab > Unlock account) and ask the user to retry with the newly-set password, typed manually rather than pasted (to rule out a copy-paste whitespace issue).
14. Verify replication between DC01 and DC02 with repadmin /replsummary - if replication is behind, force it with repadmin /syncall and retest.
15. On the affected workstation, run klist purge to clear cached Kerberos tickets, then attempt a fresh logon.
16. Check the workstation's system clock against the DC - anything beyond 5 minutes of drift will break Kerberos regardless of a correct password.
17. Confirm the workstation's DNS settings point to a DC that is actually up and has received the password change.
18. Once logon succeeds, separately test access to \\FS01\HR-Data - if it still fails, check the user's current group membership (GG-HR-Staff) and the folder's Security tab, since this may be an unrelated permissions change rather than an authentication issue.
19. Document every check performed and its result as you go - this becomes the basis for the incident report below.

6.3 AD Components to Check

- Active Directory Users and Computers - account status (locked/disabled), group membership.
- Active Directory Sites and Services / repadmin - inter-DC replication health.
- DNS Manager - SRV records for the DC, and the client's configured DNS server.
- Group Policy Management - any GPO recently linked to the user's OU (logon-hours, deny-logon-locally, password policy changes).
- NTFS & Share permissions on \\FS01\HR-Data.

6.4 Windows Logs That Help

- Security log on the Domain Controller - Event ID 4625 (failed logon) with its Failure Reason code, Event ID 4740 (account lockout), Event ID 4724 (password reset).
- Security log on the client workstation - local logon failures and the specific Kerberos error returned (e.g. KRB_AP_ERR_SKEW for clock drift).
- Directory Service log - replication errors between DC01 and DC02.
- File Server (FS01) Security log - Event ID 5145/4656 for the failed HR-Data access attempt, confirming whether it's a permissions denial rather than an authentication failure.

6.5 Verifying DNS, Group Policy and Kerberos

Area	Verification Method
DNS	nslookup techsecure.local from the client should resolve to a live DC; ipconfig /all should show a DC as the configured DNS server (not a public/ISP DNS).
Group Policy	gpresult /r on the workstation shows exactly which GPOs are currently applied to the user/computer; gpupdate /force followed by a fresh gpresult /h report.html confirms nothing unexpected (e.g. a logon-hours restriction) is being applied.
Kerberos	klist confirms whether a valid TGT is present after logon; time sync is checked with w32tm /query /status on both the client and the DC to rule out clock-skew failures.

6.6 Final Incident Report

Incident ID	INC-2026-0041
Reported By	End user (HR department)
Symptoms	Unable to log in to domain following a password reset performed the previous day; unable to access \\FS01\HR-Data.
Root Cause	The password reset was performed against DC01, but the user's workstation authenticated against DC02 before the change had replicated. Cached Kerberos tickets on the workstation compounded the issue by continuing to attempt authentication with stale ticket data even once replication caught up.
Resolution	Forced AD replication between DC01 and DC02 (repadmin /syncall), cleared cached Kerberos tickets on the affected workstation (klist purge), and had the user log on again successfully. HR-Data access was confirmed working once logon succeeded, so no separate group-membership issue was present in this case.
Preventive Action	Reduced the AD Sites replication interval for password-critical changes and added a note to the helpdesk runbook: after any password reset, proactively run repadmin /syncall from the DC that processed the change rather than waiting for the scheduled interval.

Challenges Faced

Getting the OU structure right took a couple of attempts - my first draft put every OU flat under the domain root, and it was only once I started mapping GPOs to it in Task 3 that I realised targeting would get messy (a USB-block policy would either hit IT unnecessarily or need constant exceptions). Splitting into Departments/Infrastructure with Servers and Workstations kept separate solved that cleanly.

The least-privilege review in Task 2.5 was harder than expected - it's easy to design permissions that look correct on paper but only surface real conflicts (like the Payroll cross-department access) once you actually walk through each user's effective rights individually rather than group-by-group.

For Task 5, keeping the enumeration strictly inside an isolated lab network (no bridged adapter, no internet-routable IP) took a bit of VM network configuration up front, but it was worth doing properly rather than risking scanning anything outside the lab.

Conclusion

This assignment covered the full lifecycle of an enterprise Active Directory deployment - from forest/domain planning and OU design through to user/group provisioning, permission hardening, Group Policy configuration, and incident troubleshooting. The recurring theme across every task was the same: security in AD is rarely one big control, it's a lot of small, deliberate decisions (where an OU sits, which group gets Modify vs. Read, which port shows up in an nmap scan) that add up to a defensible environment. The CIA triad shows up concretely throughout - Confidentiality in the Deny ACEs and OU isolation, Integrity in the audit policy and controlled group management, and Availability in the two-DC, two-site design that keeps authentication working even if one office loses connectivity.

References

- Microsoft Learn - Active Directory Domain Services Overview, learn.microsoft.com
- Microsoft Learn - Group Policy Objects Documentation, learn.microsoft.com
- Microsoft Learn - Kerberos Authentication Overview, learn.microsoft.com
- Nmap Reference Guide, nmap.org/book/man.html
- enum4linux-ng Documentation, github.com/cddmp/enum4linux-ng
- CIS Microsoft Windows Server Benchmarks, cisecurity.org